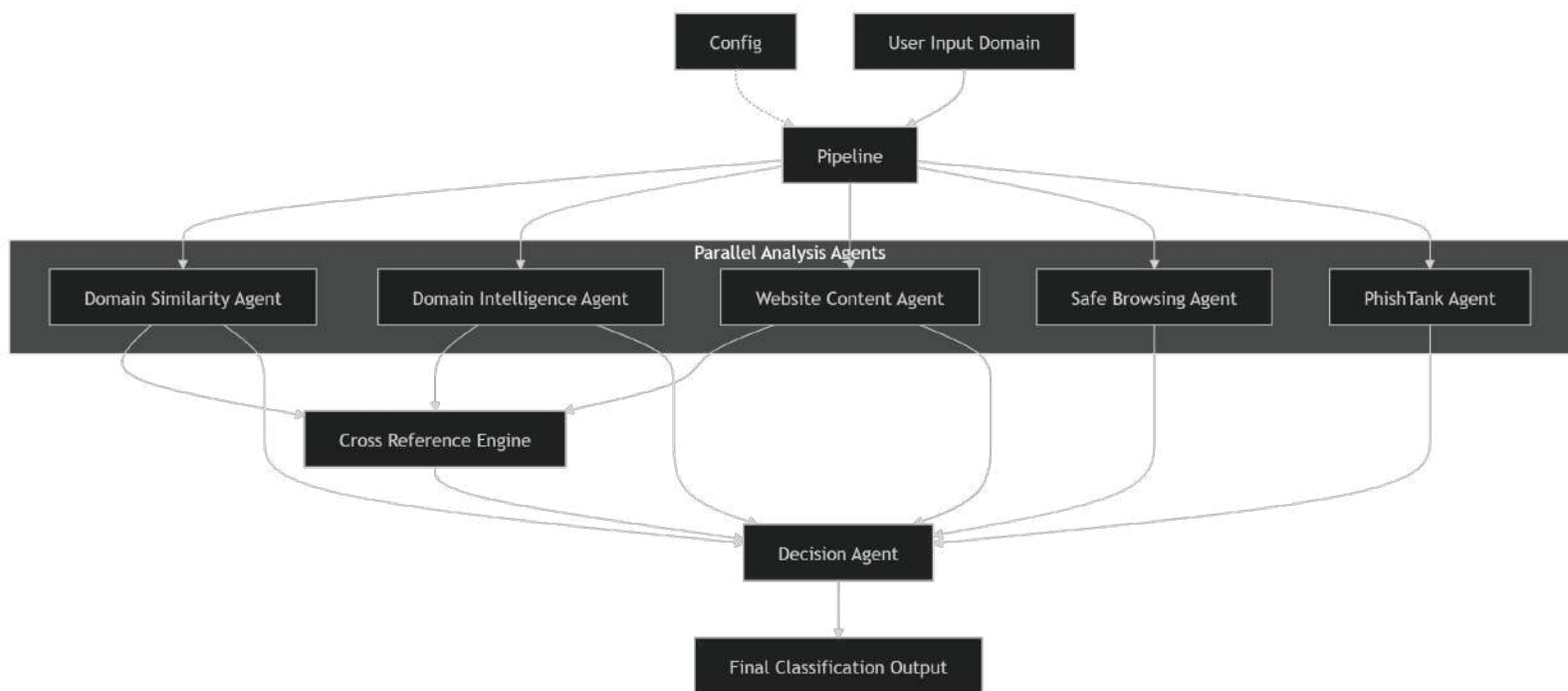




Phish-Defender AI – Component Architecture Explained

1. Config

Role: Centralized knowledge base and tuning center for the entire system.

Config acts as the single source of truth for every tunable parameter, threshold, brand list, and scoring weight used across all agents and engines. Rather than scattering magic numbers and keyword lists throughout individual agents, everything lives here – making the system easy to tune, audit, and extend without touching agent logic.

What it contains:

- **Brand Registry** – A comprehensive mapping of 75+ known brand names to their canonical domains (e.g., "paypal" → "paypal.com", "chatgpt" → "openai.com"). This is consumed by the Similarity Agent, Content Agent, and Cross Reference Engine to determine whether a domain is impersonating a well-known brand.
- **Brand Domain Aliases** – A mapping that groups related domains under a single organization. For example, `bing.com`, `outlook.com`, `azure.com`, and `office.com` all belong to the Microsoft family. This prevents false positives where a legitimate sub-brand mentions its parent company.
- **Ambiguous & SSO Brand Lists** – Brands that are also common English words (e.g., "chase", "steam", "regions", "meta") or frequently appear in social login buttons (e.g., "Sign in with Google"). These require stricter detection rules to avoid false flags on unrelated websites.
- **Brand Tiers** – Classifies brands by sector (`finance_global`, `finance_eu`, `tech_social`) so the system can apply proportionally higher risk scores when financial brands are being impersonated.
- **Keyword Dictionaries** – Curated lists of phishing domain keywords, suspicious content phrases, payment-related terms, tech support scam indicators, and multilingual OTP/verification code patterns.
- **Hosting Platform Registry** – A list of known free hosting platforms (Vercel, Netlify, Heroku, GitHub Pages, etc.) that are commonly abused for throwaway phishing subdomains.
- **Scoring Weights & Thresholds** – The exact weight each agent carries in the final risk score calculation, the classification thresholds for PHISHING vs SUSPICIOUS vs SAFE, and the corroboration boost applied when multiple agents agree.
- **Cross Reference Engine Parameters** – The risk values assigned to each type of cross-agent correlation signal (brand impersonation on hosted platforms, payment forms on disposable domains, etc.).

Interaction: Config is a passive dependency – it does not execute logic. Every other component imports constants from Config to drive their decisions.

2. User Input Domain

Role: Entry gate that accepts raw user input and produces a clean, normalized, validated domain.

This is the first component that touches user-provided data. Its job is to take whatever the user types – whether a bare domain like `google.com`, a full URL like `https://www.login-paypal-secure.net/auth/verify`, or something messy with trailing slashes and mixed casing – and transform it into two clean outputs that the rest of the pipeline can safely consume.

What it does:

- **Accepts** raw user input (string – could be a domain, a URL, or anything in between).
- **Extracts** the root domain by parsing the input, stripping common prefixes like `www.`, and isolating the hostname.
- **Normalizes** the URL by ensuring it has a proper scheme (`http://` if missing), lowercasing everything, and cleaning up trailing slashes for consistency.
- **Validates** that the extracted domain matches a valid domain format – rejecting empty inputs, excessively long strings, and anything that doesn't look like a real domain.

Output: A structured result containing two values:

- `clean_domain` – The bare, lowercase domain (e.g., `login-paypal-secure.net`) used by agents that analyze the domain name itself.
- `full_url` – The normalized URL (e.g., `http://login-paypal-secure.net/auth/verify`) used by agents that need to fetch the actual web page.

Interaction: Sits at the very front of the pipeline. The Pipeline component calls it first and distributes its two outputs to all downstream agents – some receive the clean domain, others receive the full URL, depending on what they need.

3. Pipeline

Role: Central orchestrator that coordinates the entire analysis workflow from input to final output.

The Pipeline is the brain of the system's execution flow. It does not perform any analysis itself – instead, it launches agents, manages their lifecycle, enforces time budgets, handles failures gracefully, and assembles the final result.

What it does:

1. **Input Processing** – Calls User Input Domain to clean and validate the raw domain. Also evaluates whether the target website is reachable by performing a lightweight network probe, classifying the target as LIVE, BLOCKED, UNREACHABLE, or ERROR.
2. **Parallel Agent Dispatch** – Launches four "fast" agents simultaneously in parallel threads:

- Domain Similarity Agent (receives clean domain)
 - Domain Intelligence Agent (receives clean domain)
 - Safe Browsing Agent (receives full URL) — if enabled
 - PhishTank Agent (receives full URL) — if enabled
3. **Timeout Enforcement** — Each agent is given a hard time ceiling (7 seconds). The entire pipeline has a global deadline (30 seconds). If an agent doesn't finish in time, the pipeline proceeds with safe default values and marks that agent as "degraded."
 4. **Smart Content Agent Scheduling** — The Website Content Agent is the heaviest operation (it may render JavaScript). The pipeline runs it *after* the fast agents complete, and applies three early-exit optimizations:
 - If the time budget is nearly exhausted, it skips the content agent entirely.
 - If Safe Browsing or PhishTank already confirmed the domain is malicious, it skips the expensive page rendering.
 - If the network probe showed the site is unreachable, it skips the content agent.
 5. **Post-Agent Correlation** — After all agents complete, the pipeline feeds the Similarity, Intelligence, and Content outputs into the Cross Reference Engine for cross-agent correlation analysis.
 6. **Final Decision** — Feeds all agent outputs plus the Cross Reference Engine output into the Decision Agent to produce the final classification.
 7. **Metadata Enrichment** — Attaches timing information, error details, and degradation flags to the final response so the frontend can show users which agents ran successfully and which had issues.

Interaction: The Pipeline is called by the Flask `/analyze` endpoint and returns the complete analysis result. It is the only component that directly interacts with all other components.

4. Domain Similarity Agent

Role: Detects whether a domain name is attempting to impersonate a known brand through typosquatting, homograph attacks, or keyword stuffing.

This agent focuses exclusively on the *domain name itself*— it never visits the website or checks any external databases. It answers the question: "Does this domain name look suspiciously similar to a legitimate brand?"

What it analyzes:

- **Brand Alias Recognition** — First checks if the domain is a known legitimate alias of a brand (e.g., `discord.gg` is an official Discord domain, `github.io` belongs to GitHub). If so, it immediately returns zero risk — this is not impersonation.
- **Homograph Normalization** — Translates Unicode characters that visually resemble Latin letters (Cyrillic `а` → `a`, `о` → `o`) and ASCII look-alikes (`0` → `o`, `1` → `l`, `$` → `s`) to catch domains like `google.com` (with Cyrillic 'o' characters).
- **Brand Containment Detection** — Checks if a known brand name is embedded within the domain (e.g., `paypal` inside `login-paypal-secure.net`). Short brand names (≤3 characters) require standalone segment matching to avoid false positives.
- **Fuzzy Similarity Matching** — Computes how closely the domain resembles any known brand using multiple fuzzy matching algorithms (exact ratio, partial match, and token rearrangement). This catches typosquatting like `goggle.com`, `amaz0n.com`, or `netf11x.com`.
- **Phishing Keyword Detection** — Scans the domain name for suspicious keywords commonly used in phishing campaigns (`login`, `secure`, `verify`, `account`, `billing`, etc.).
- **Risk Scoring** — Combines all signals into a risk score, with non-linear scaling: a domain that contains a brand name AND uses phishing keywords AND closely resembles a known domain receives a much higher score than any single signal alone. Financial brands receive an additional risk premium.

Output: A structured result containing the risk score, detected brand name (if any), closest matching brand, similarity score, and list of phishing keywords found in the domain.

Interaction: Receives the clean domain from the Pipeline. Its output feeds into both the Cross Reference Engine (for correlation with content signals) and the Decision Agent (for final scoring).

5. Domain Intelligence Agent

Role: Investigates the domain's registration history, DNS infrastructure, and SSL posture to assess its trustworthiness.

This agent examines the *infrastructure behind the domain* — not the domain name or website content, but who registered it, when, how it's configured, and whether its technical setup is consistent with a legitimate operation.

What it investigates:

- **Domain Age** — Determines how long ago the domain was registered. Phishing domains are overwhelmingly young — most are less than 30 days old. The agent uses a graduated risk model: domains under 7 days are treated as very high risk, under 30 days as elevated, and domains over a year old receive minimal age-related risk.
- **Registration Span** — Checks whether the domain was registered for the minimum possible period (less than ~13 months). Legitimate businesses typically register domains for multiple years, while phishing operators pay for the shortest term available.
- **WHOIS Privacy** — Detects whether the registrant information is hidden behind a privacy service. WHOIS privacy alone is not suspicious (many legitimate sites use it), but combined with a very new domain, it becomes a significant red flag.
- **Hosting Platform Detection** — Identifies whether the domain is hosted on a known free/shared hosting platform (Vercel, Netlify, Heroku, GitHub Pages, etc.). These platforms are frequently abused because they allow instant, anonymous deployment of phishing pages.
- **DNS Records** — Checks for the presence of MX (mail) records and counts nameservers. Legitimate domains typically have MX records and redundant nameservers. A domain with no MX records and a single nameserver shows minimal infrastructure investment.

- **DNSSEC** — Checks whether the domain has DNSSEC enabled, indicating investment in DNS security infrastructure — a positive trust signal.
- **SSL Certificate** — Verifies whether the domain has a valid SSL certificate. While free SSL certificates have reduced the discriminative power of this check, the *absence* of SSL on a modern website remains a moderate negative signal.
- **Risk Scoring** — Combines all signals using graduated, additive scoring with positive trust adjustments. Valid SSL and DNSSEC reduce the risk score; new registration, missing MX, and short expiry increase it.

Output: A structured result containing domain age, hosting platform status, SSL validity, and the composite risk score.

Interaction: Receives the clean domain from the Pipeline. Its output feeds into the Cross Reference Engine (for correlation with brand and content signals) and the Decision Agent (for final scoring). Its `is_hosted_platform` flag is particularly important — it changes how the Decision Agent weights all other signals.

6. Website Content Agent

Role: Downloads and analyzes the actual web page content to detect phishing indicators in the page structure, forms, and text.

This is the heaviest and most information-rich agent. While other agents examine the domain's name and infrastructure, this agent actually visits the website and examines what the page contains. It answers the question: "Does this page look and behave like a phishing page?"

What it analyzes:

- **Page Fetching** — Retrieves the target page using a full browser engine when available (for JavaScript-rendered content) or falls back to standard HTTP requests. This is critical because modern phishing pages are often built with React, Vue, or other JavaScript frameworks that produce empty HTML without rendering.
- **Login Form Detection** — Identifies password fields, email/username inputs, and form structures that indicate credential collection. Uses both structural analysis (HTML form elements) and attribute inspection to catch obfuscated or framework-based login forms.
- **Cross-Domain Form Submission** — Detects forms that submit data to a different domain than the page is hosted on — a strong credential harvesting indicator (e.g., a page on `login-paypal-secure.net` that submits form data to `evil-collector.xyz`).
- **Brand Impersonation Detection** — Scans page content (title, headings, body text, image attributes, meta tags) for mentions of known brand names that don't match the hosting domain. Uses context-aware filtering: high-signal locations like titles and headings carry more weight than body text. Ambiguous brand names (words that are also common English words) require prominent placement to trigger. Brand mentions that belong to the same corporate family are excluded.
- **Payment & Financial Data Collection** — Detects input fields and text patterns associated with credit card collection (card number, CVV, expiration date) and payment processing iframes.
- **Scam Indicator Detection** — Identifies tech support scam patterns: scare-tactic keywords ("virus detected", "computer locked"), toll-free phone numbers near support-related text, and fake security alerts.
- **OTP/Verification Code Detection** — Recognizes pages designed to intercept one-time passwords or verification codes, with multilingual keyword support.
- **Structural Anomalies** — Detects suspicious iframes, hidden input fields, meta-refresh redirects, JavaScript redirects, obfuscated scripts, and "lonely form" patterns (pages with almost no content except a single input form).
- **Provider Block Page Detection** — Identifies when URL shorteners (TinyURL, Bit.ly) have proactively blocked a link, treating a blocked shortlink as a confirmed malicious indicator.
- **Legitimate App Behavior** — Conversely, identifies positive signals suggesting the page is a legitimate application: proper title, no forms, no suspicious keywords, no redirects, and normal content structure.

Output: A comprehensive result with over 15 fields including login form detection, brand impersonation list, payment form status, scam indicators, risk score, final URL (after redirects), and the final domain the page landed on.

Interaction: Receives the full URL from the Pipeline. Its output feeds into the Cross Reference Engine (for correlation with domain-level signals) and the Decision Agent (for final scoring). Its brand impersonation detection is validated by the CRE to eliminate false positives.

7. Safe Browsing Agent

Role: Checks the URL against Google's Safe Browsing threat database — an authoritative, industry-standard blocklist.

This agent acts as an external intelligence lookup. Google's Safe Browsing database is continuously updated with known malicious URLs reported worldwide, making it one of the most reliable signals available. A positive match from Safe Browsing carries the highest authority in the system.

What it does:

- **API Lookup** — Sends the target URL to the Google Safe Browsing API, querying for four threat categories: malware, social engineering (phishing), unwanted software, and potentially harmful applications.
- **Resilience** — Implements a circuit breaker pattern: if the API fails repeatedly (3 consecutive failures), the agent stops making calls for a cooldown period to prevent cascading latency. After the cooldown, it attempts a single probe request to check if the API has recovered.
- **Fail-Open Policy** — If the API is unavailable (no API key configured, circuit breaker open, or network error), the agent returns a "safe" result by default. This ensures the system doesn't block legitimate sites just because a third-party API is down. The agent reports itself as disabled so other components can adjust their confidence accordingly.

Output: A result containing whether the URL is safe, any threat matches found, and a binary risk score (0.0 for safe, 1.0 for flagged).

Interaction: Receives the full URL from the Pipeline. Its output goes directly to the Decision Agent (not the Cross Reference Engine). A positive match from Safe Browsing triggers an **override** in the Decision Agent — the final classification is immediately set to PHISHING with maximum confidence, bypassing all other scoring logic.

8. PhishTank Agent

Role: Checks the URL against PhishTank's community-maintained database of verified phishing URLs.

PhishTank is a collaborative clearinghouse where users submit and verify phishing URLs. Unlike Google Safe Browsing (which covers broad threat categories), PhishTank is specifically focused on phishing, making it a valuable complementary signal.

What it does:

- **Local Database Lookup** — Maintains a local copy of the PhishTank database (compressed JSON) that is loaded into an in-memory set for instantaneous lookups. This avoids per-request API calls and ensures sub-millisecond lookup latency.
- **Background Refresh** — Checks the age of the local database and triggers a background download if it's older than 1 hour. The refresh happens in a background thread so it never blocks user requests. If the initial database file doesn't exist at startup, it is downloaded in the background while the system begins serving requests.
- **URL Normalization** — Strips schemes and normalizes URLs to match the format used in the PhishTank dataset, ensuring consistent lookups regardless of whether the user provided `http://`, `https://`, or no scheme.

Output: A result containing whether the URL was found in the PhishTank database and a risk score (0.8 if found, 0.0 if not).

Interaction: Receives the full URL from the Pipeline. Its output goes directly to the Decision Agent (not the Cross Reference Engine). A PhishTank match sets a minimum floor on the final risk score, ensuring the domain is classified as at least SUSPICIOUS even if other agents report low risk.

9. Cross Reference Engine

Role: Correlates signals across multiple agents to detect compound attack patterns that no individual agent can identify alone.

The Cross Reference Engine is the system's **correlation layer**. Individual agents are specialists — one looks at the domain name, another at the infrastructure, another at the page content. But phishing attacks are multi-dimensional: a truly convincing phishing page will have a domain that resembles a brand, hosted on a disposable platform, serving content that impersonates that brand with credential collection forms. The CRE detects these multi-signal patterns.

What it does:

- **Brand Alias Filtering** — Before analyzing brand mentions from the Content Agent, the CRE filters out mentions that belong to the same corporate family as the page's domain. For example, if `bing.com` mentions "Microsoft," that's legitimate — they're the same company. This filtering uses the brand alias registry from Config to prevent false positives.
- **Brand-Content Mismatch** — Detects when the page content references brands that don't match the actual domain. A page on `random-hosting.vercel.app` mentioning "PayPal" multiple times is a mismatch.
- **Brand-Domain Mismatch** — Detects when the domain name itself contains a brand name but is hosted on a shared platform. A subdomain like `paypal-login.herokuapp.com` combines brand impersonation in the domain with free hosting infrastructure.
- **Hosted Brand Impersonation** — The highest-risk correlation: when the domain name impersonates a brand, the page content also references that brand, AND the site is on a known hosting platform. This triple alignment is the strongest compound phishing signal.
- **Credential/Payment + Impersonation** — Detects when brand impersonation co-occurs with login form or payment form collection on untrusted domains. A login page impersonating a bank on a new domain is far more dangerous than a login page on an established domain.
- **Scam + Disposable Domain** — Detects tech support scam indicators appearing on new or hosted domains — the hallmark of throwaway scam pages.
- **Established Domain Trust** — Applies a risk discount for domains that are more than 2 years old with valid SSL certificates, recognizing that well-established domains are far less likely to be phishing operations.

Input: Outputs from three agents — Domain Similarity, Domain Intelligence, and Website Content.

Output: A correlation result containing boolean flags for each pattern detected and a composite cross-reference risk score.

Interaction: Sits between the agent layer and the Decision Agent. It only receives data from three agents — Safe Browsing and PhishTank bypass the CRE because they are already authoritative signals that don't benefit from correlation. Its output feeds into the Decision Agent as an additional weighted input.

10. Decision Agent

Role: Final aggregation and classification engine that combines all agent outputs and cross-reference signals into a single phishing verdict.

The Decision Agent is the system's **judgment layer**. It receives every piece of evidence gathered by every upstream component and synthesizes it into a clear, actionable classification with confidence levels, severity ratings, and human-readable explanations.

What it does:

- **Authoritative Overrides** — Before any weighted scoring, the Decision Agent checks for authoritative signals. If Google Safe Browsing flagged the URL as malicious, the classification is immediately set to PHISHING with maximum confidence and severity CRITICAL — no further analysis needed. PhishTank matches set a minimum score floor, ensuring the result is at least SUSPICIOUS.
- **Trust Anchor Breaking** — Detects scenarios where a normally trusted domain may have been compromised. If a domain has clean infrastructure (low intelligence risk) but the URL path contains deep, high-entropy randomized segments (characteristic of injected phishing pages on hacked sites), the intelligence risk is overridden upward.
- **Weighted Score Calculation** — Computes a composite risk score by weighting each agent's output. The weights are dynamic — they change based on context:

- When Safe Browsing reports a positive risk, it receives the highest weight (35%).
 - When there's no Safe Browsing signal but the CRE has a correlation signal, the CRE gets significant weight (30%).
 - When the domain is on a known hosting platform, the Intelligence Agent's weight is reduced (since infrastructure signals are meaningless for shared hosting) and the Content Agent's weight is increased.
- **Combo Detection** — Identifies deadly signal combinations that individually might not trigger alerts but together are near-certain phishing indicators:
 - New domain + login form
 - Hosted platform + login form + high brand similarity
 - High brand similarity on a hosted platform
 - Open redirect to a different domain with a login form
 - Provider (URL shortener) actively blocking the link
 - **Graceful Degradation** — Applies positive trust adjustments when evidence suggests the page is legitimate: valid SSL, legitimate app behavior patterns, established domain age (>2 years). These adjustments prevent false positives on well-known sites that happen to trigger minor signals. These adjustments are *never* applied to hosted platforms or provider-blocklisted domains.
 - **Signal Amplification** — When 2 or more agents independently report high risk (≥ 0.40), a corroboration boost is applied to the composite score. Multiple agents agreeing significantly increases confidence in the result.
 - **Classification** — Maps the final score to a label using threshold-based rules:
 - **PHISHING** — Score exceeds the phishing threshold (0.55 for established domains, 0.45 for new/hosted domains)
 - **SUSPICIOUS** — Score exceeds the suspicious threshold (0.35) but not phishing
 - **SAFE** — Score below the suspicious threshold
 - **UNKNOWN** — Network state prevented adequate analysis (site blocked, unreachable, or erroring)
 - **Confidence & Severity** — Computes a confidence level (HIGH, MEDIUM, LOW) based on how far the score is from the classification boundary, and a severity level (CRITICAL, HIGH, MEDIUM, LOW, INFO) based on the presence of authoritative signals and the magnitude of the risk score.
 - **Explanation Generation** — Produces a structured list of human-readable explanation items, each tagged with a category (which agent produced it), a clear signal description, and an impact rating. This gives users full transparency into *why* the system reached its conclusion.

Input: All five agent outputs + Cross Reference Engine output + network state.

Output: The final result containing:

- Individual risk scores from each agent
- Final composite risk score
- Classification label (PHISHING / SUSPICIOUS / SAFE / UNKNOWN)
- Confidence level
- Severity level
- Structured explanations
- Raw outputs from all agents (for transparency)

Interaction: The terminal component in the pipeline. Its output is returned through the Pipeline to the Flask endpoint and ultimately to the user as the API response.